Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each control, including the type and purpose, refer to the control categories document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☑	Least Privilege
☐	☑	Disaster recovery plans
☐	☑	Password policies
☐	☑	Separation of duties
☑	☐	Firewall
☐	☑	Intrusion detection system (IDS)
☐	☑	Backups
☑	☐	Antivirus software
☑	☐	Manual monitoring, maintenance, and intervention for legacy systems
☐	☑	Encryption
☐	☑	Password management system
☑	☐	Locks (offices, storefront, warehouse)
☑	☐	Closed-circuit television (CCTV) surveillance

☑	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

To complete the compliance checklist, refer to the information provided in the scope, goals, and risk assessment report. For more details about each compliance regulation, review the controls, frameworks, and compliance reading.

Then, select "yes" or "no" to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☑	Only authorized users have access to customers' credit card information.
☐	☑	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☑	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☑	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☑	E.U. customers' data is kept private/secured.
☑	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☑	Ensure data is properly classified and inventoried.

☑	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☑	User access policies are established.
☐	☑	Sensitive data (PII/SPII) is confidential/private.
☑	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☑	☐	Data is available to individuals authorized to access it.

This section is *optional* and can be used to provide a summary of recommendations to the IT manager regarding which controls and/or compliance best practices Botium Toys needs to implement, based on the risk posed if not implemented in a timely manner.

Recommendations (optional):

Recommendations are listed in order of priority, starting with the risks most likely to cause data loss or regulatory fines.

1. Ensure only authorized personnel can view PII/SPII and payment card details, using role-based access. This restriction would help to implement least privilege and separation of duties.
2. All credit card data should be encrypted at rest and in transit to satisfy PCI DSS requirements, and PII/SPII should also be safeguarded for data subjects to comply with GDPR and SOC standards.

3. Create regular backups of critical data and test restoring them. A formal disaster recovery plan should be developed, and backups should be automated, so that rapid recovery from system failures or security events is not compromised.
4. Install an intrusion detection system (IDS) alongside the firewall to detect and alert on malicious network traffic.
5. Password controls and centralised management should be enforced. For instance, a minimum password length of 8 characters, with a mix of uppercase and lowercase letters, at least one number and a special character (*<,@#.). Centralised password management should also be enforced to reduce administrative burden, cut password-reset delays and lower brute-force risks.
6. Implement a routine schedule for the maintenance and monitoring of end-of-life legacy systems.
7. The NIST CSF Identify function must be fulfilled by making a formal inventory of all assets (hardware, data, software) and assessing the impact of their loss on business continuity.

Existing strengths include a rule-based firewall, monitored antivirus software, a 72-hour breach notification plan for E.U. customers, enforced privacy policies, and good physical security (locks, CCTV, and fire detection and prevention).